# ZAP Report - AFTER fix (IDOR & Mass Assignment) - IT22105820

College Management System backend at commit 5469287 (current develop, after PR #10 and #12). Requests for students, faculty and admin were proxied through OWASP ZAP 2.16. Access-control and mass-assignment tests were performed manually with ZAP and recorded as alerts; ZAP's passive scanner also ran on all traffic.

## Site: http://localhost:4000

### Generated on Wed, 14 Oct 2026 13:47:41

### ZAP Version: 2.16.0

**ZAP by Checkmarx**

### Summary of Alerts

| Risk Level | Number of Alerts |
|---|---|
| High | 0 |
| Medium | 0 |
| Low | 0 |
| Informational | 9 |
| False Positives: | 0 |

### Alerts

| Name | Risk Level | Number of Instances |
|---|---|---|
| Authentication Request Identified | Informational | 3 |
| Retest PASSED - Broken Access Control (IDOR) (T1) | Informational | 1 |
| Retest PASSED - Mass Assignment (T6) | Informational | 1 |
| Retest PASSED - Mass Assignment (T7) | Informational | 1 |
| Retest PASSED - Missing Authorization (T2) | Informational | 1 |
| Retest PASSED - Missing Authorization (T3) | Informational | 1 |
| Retest PASSED - Missing Authorization (T4) | Informational | 1 |
| Retest PASSED - Missing Authorization (T5) | Informational | 1 |
| Session Management Response Identified | Informational | 3 |

### Alert Detail

| Informational | Authentication Request Identified |
|---|---|
| Description | The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified. |

| | |
|---|---|
| URL | http://localhost:4000/api/admin/login |
| Method | POST |
| Attack | |
| Evidence | password |
| Other Info | userParam=email userValue=admin@college.lk passwordParam=password |
| URL | http://localhost:4000/api/faculty/login |
| Method | POST |
| Attack | |
| Evidence | password |
| Other Info | userParam=email userValue=faculty@college.lk passwordParam=password |
| URL | http://localhost:4000/api/student/login |
| Method | POST |
| Attack | |
| Evidence | password |
| Other Info | userParam=email userValue=alice@college.lk passwordParam=password |
| Instances | 3 |
| Solution | This is an informational alert rather than a vulnerability and so there is nothing to fix. |
| Reference | https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/ |
| CWE Id | |
| WASC Id | |
| Plugin Id | 10111 |

| **Informational** | **Retest PASSED - Broken Access Control (IDOR) (T1)** |
|---|---|
| Description | Manual retest (T1) of: Broken Access Control (IDOR): student can modify another student's record. Same request proxied through ZAP. The server rejected it or ignored the dangerous fields (HTTP 403). Not vulnerable. |
| URL | http://localhost:4000/api/student/6acf3aa156aad59b0932c7a2 |
| Method | PATCH |
| Attack | Logged in as student Alice, sent PATCH /api/student/6acf3aa156aad59b0932c7a2 (Bob's ID) with {"firstName":"Hacked"} |
| Evidence | You do not have permission to perform this action |
| Other Info | Commit under test: 5469287 (current develop, after PR #10 and #12) |
| Instances | 1 |
| Solution | No action required. |
| Reference | https://owasp.org/Top10/A01_2021-Broken_Access_Control/<br>https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/<br>https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html |
| CWE Id | 639 |
| WASC Id | 2 |
| Plugin Id | |

| **Informational** | **Retest PASSED - Mass Assignment (T6)** |
|---|---|
| | |

| | |
|---|---|
| Description | Manual retest (T6) of: Mass Assignment: privilege escalation via isSuperAdmin / googleId / employeeId. Same request proxied through ZAP. The server rejected it or ignored the dangerous fields (HTTP 200). Not vulnerable. |
| URL | http://localhost:4000/api/admin/6acf3aa156aad59b0932c79b |
| Method | PATCH |
| Attack | Logged in as a normal admin, sent PATCH /api/admin/<own id> with extra fields {"isSuperAdmin":true,"googleId":"attacker-google-sub","employeeId":1} |
| Evidence | "isSuperAdmin":false |
| Other Info | Commit under test: 5469287 (current develop, after PR #10 and #12) |
| Instances | 1 |
| Solution | No action required. |
| Reference | https://owasp.org/Top10/A01_2021-Broken_Access_Control/<br>https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/<br>https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html |
| CWE Id | 915 |
| WASC Id | 20 |
| Plugin Id | |

| **Informational** | **Retest PASSED - Mass Assignment (T7)** |
|---|---|
| Description | Manual retest (T7) of: Mass Assignment: MongoDB update operator injection ($unset deletes data). Same request proxied through ZAP. The server rejected it or ignored the dangerous fields (HTTP 200). Not vulnerable. |
| URL | http://localhost:4000/api/branch/6acf3aa156aad59b0932c797 |
| Method | PATCH |
| Attack | Sent PATCH /api/branch/<id> with body {"$unset":{"name":1}} |
| Evidence | "name":"Information Technology" |
| Other Info | Commit under test: 5469287 (current develop, after PR #10 and #12) |
| Instances | 1 |
| Solution | No action required. |
| Reference | https://owasp.org/Top10/A01_2021-Broken_Access_Control/<br>https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/<br>https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html |
| CWE Id | 915 |
| WASC Id | 20 |
| Plugin Id | |

| **Informational** | **Retest PASSED - Missing Authorization (T2)** |
|---|---|
| Description | Manual retest (T2) of: Missing Authorization: student can change another student's marks. Same request proxied through ZAP. The server rejected it or ignored the dangerous fields (HTTP 403). Not vulnerable. |
| URL | http://localhost:4000/api/marks/bulk |
| Method | POST |
| Attack | Logged in as student Alice, sent POST /api/marks/bulk setting Bob's mark (was 78) to 0 |
| Evidence | You do not have permission to perform this action |
| Other Info | Commit under test: 5469287 (current develop, after PR #10 and #12) |
| Instances | 1 |

| | |
|---|---|
| Solution | No action required. |
| Reference | https://owasp.org/Top10/A01_2021-Broken_Access_Control/<br>https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/<br>https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html |
| CWE Id | 285 |
| WASC Id | 2 |
| Plugin Id | |

| **Informational** | **Retest PASSED - Missing Authorization (T3)** |
|---|---|
| Description | Manual retest (T3) of: Missing Authorization: student can read every student's personal data. Same request proxied through ZAP. The server rejected it or ignored the dangerous fields (HTTP 403). Not vulnerable. |
| URL | http://localhost:4000/api/student |
| Method | GET |
| Attack | Logged in as student Alice, sent GET /api/student (admin-only list) |
| Evidence | You do not have permission to perform this action |
| Other Info | Commit under test: 5469287 (current develop, after PR #10 and #12) |
| Instances | 1 |
| Solution | No action required. |
| Reference | https://owasp.org/Top10/A01_2021-Broken_Access_Control/<br>https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/<br>https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html |
| CWE Id | 285 |
| WASC Id | 2 |
| Plugin Id | |

| **Informational** | **Retest PASSED - Missing Authorization (T4)** |
|---|---|
| Description | Manual retest (T4) of: Missing Authorization: student can modify an admin account. Same request proxied through ZAP. The server rejected it or ignored the dangerous fields (HTTP 403). Not vulnerable. |
| URL | http://localhost:4000/api/admin/6acf3aa156aad59b0932c79b |
| Method | PATCH |
| Attack | Logged in as student Alice, sent PATCH /api/admin/6acf3aa156aad59b0932c79b with {"designation":"Pwned by student"} |
| Evidence | You do not have permission to perform this action |
| Other Info | Commit under test: 5469287 (current develop, after PR #10 and #12) |
| Instances | 1 |
| Solution | No action required. |
| Reference | https://owasp.org/Top10/A01_2021-Broken_Access_Control/<br>https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/<br>https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html |
| CWE Id | 285 |
| WASC Id | 2 |
| Plugin Id | |

| **Informational** | **Retest PASSED - Missing Authorization (T5)** |
|---|---|
| | |

| | |
|---|---|
| Description | Manual retest (T5) of: Missing Authorization: faculty can perform admin-only action (create branch). Same request proxied through ZAP. The server rejected it or ignored the dangerous fields (HTTP 403). Not vulnerable. |
| URL | http://localhost:4000/api/branch |
| Method | POST |
| Attack | Logged in as faculty Kamal, sent POST /api/branch |
| Evidence | You do not have permission to perform this action |
| Other Info | Commit under test: 5469287 (current develop, after PR #10 and #12) |
| Instances | 1 |
| Solution | No action required. |
| Reference | https://owasp.org/Top10/A01_2021-Broken_Access_Control/<br>https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/<br>https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html |
| CWE Id | 285 |
| WASC Id | 2 |
| Plugin Id | |

| **Informational** | **Session Management Response Identified** |
|---|---|
| Description | The given response has been identified as containing a session management token. The 'Other in the Header Based Session Management Method. If the request is in a context which has a Se rule will change the session management to use the tokens identified. |
| URL | http://localhost:4000/api/admin/login |
| Method | POST |
| Attack | |
| Evidence | eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.<br>eyJ1c2VySWQiOiI2YWNmM2FhMTU2YWFkNTliMDkzMmM3OWIiLCJyb2xlIjoiYWRtaW4iLCJp<br>c7wVtm12w8IfR5ts0myqIgpSQpO5d1NVArHOuloWYkg |
| Other Info | json:data.token |
| URL | http://localhost:4000/api/faculty/login |
| Method | POST |
| Attack | |
| Evidence | eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.<br>eyJ1c2VySWQiOiI2YWNmM2FhMTU2YWFkNTliMDkzMmM3OWUiLCJyb2xlIjoiZmFjdWx0eSIs<br>ViczaqQg-getc4Mh0BWx5vVkRWMYZYKxtGdqtbsGUMM |
| Other Info | json:data.token |
| URL | http://localhost:4000/api/student/login |
| Method | POST |
| Attack | |
| Evidence | eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.<br>eyJ1c2VySWQiOiI2YWNmM2FhMTU2YWFkNTliMDkzMmM3YTAiLCJyb2xlIjoic3R1ZGVudCIsI<br>vKvAlcNrV3sgQdu25fvVMosMrzl3bU60ix-jcv5pg7Q |
| Other Info | json:data.token |
| Instances | 3 |
| Solution | This is an informational alert rather than a vulnerability and so there is nothing to fix. |
| Reference | https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id |

| | |
|---|---|
| CWE Id | |
| WASC Id | |
| Plugin Id | 10112 |